

L2 - 12.1. Traffic Analysis Pitfalls

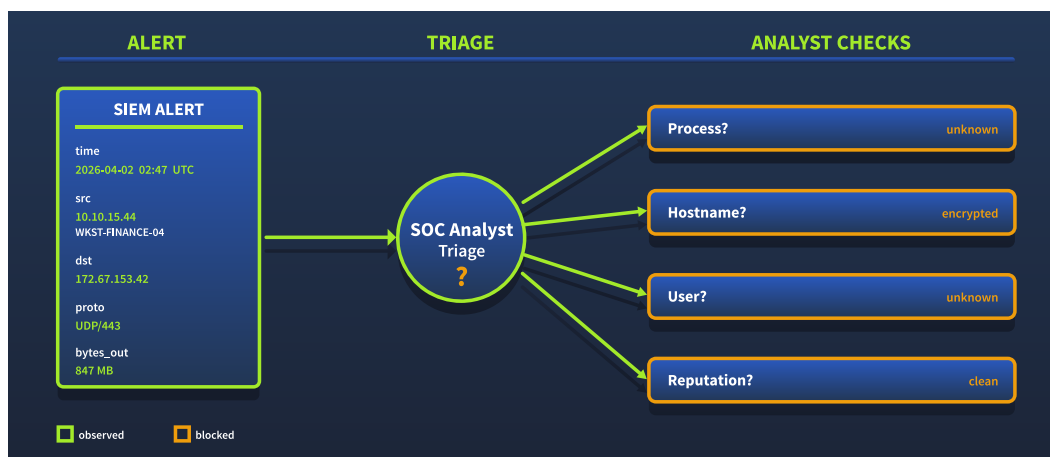
Task 1 - Introduction

It is 02:47. Our SIEM fires an alert.

```
Alert: Large Outbound Transfer
Source: 10.10.15.44 (WKST-FINANCE-04)
Destination: 172.67.153.42:443
Protocol: UDP
Bytes Out: 847 MB
Duration: 4h 12m
Time: 2026-04-02 02:47 UTC
```

- We pull the IP. Every threat intelligence feed returns the same result: **clean**.
- No malware associations, no C2 infrastructure, reputation score: **benign**.
- We check DNS logs for any query resolving to that IP: **nothing**.
- We check the TLS SNI for the destination hostname: **Encrypted**.

We have a destination IP, a port, a byte count, and a duration. Every other signal our detection stack depends on has been rendered invisible.



Traditional network traffic analysis relied on direct host-to-IP relationships, cleartext DNS hostnames, and exposed Server Name Indication (SNI) fields in TLS handshakes to identify destinations and enforce reputation-based blocking.

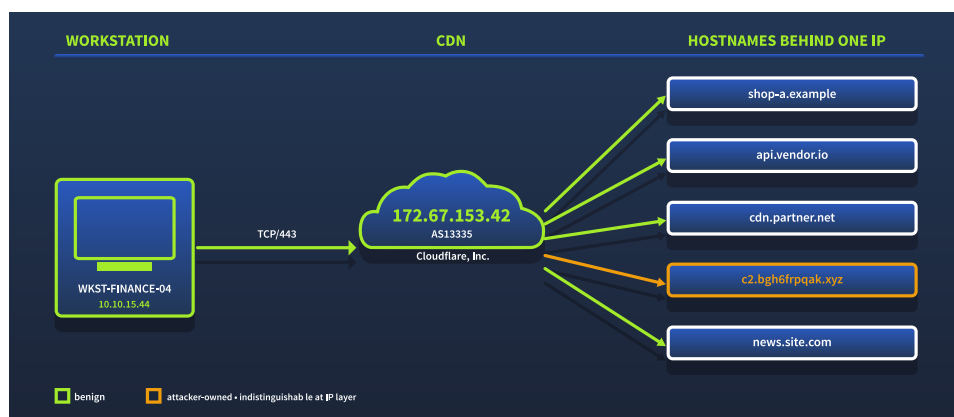
Modern web standards—including CDN-shared IPs, encrypted DNS, Encrypted Client Hello (ECH), and non-TCP protocols like QUIC—have rendered traditional traffic visibility obsolete across default browser and network setups.

This Room Covers:

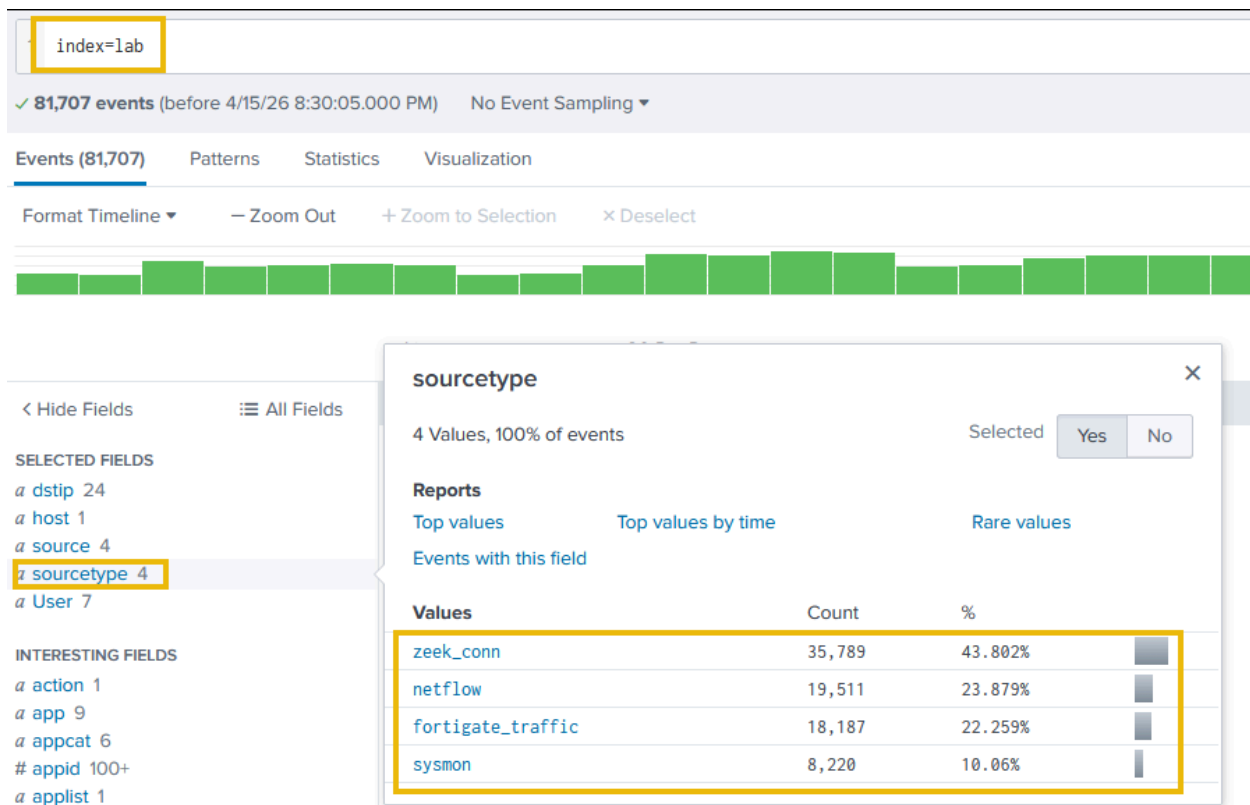
- Why IP-based monitoring fails against CDN infrastructure, and what to examine instead
- How HTTP/3 and the QUIC protocol have broken the TCP assumptions built into most detection tooling
- How DNS over HTTPS and Encrypted Client Hello eliminated two historically reliable detection signals, and what alternatives remain
- How to select the right log source for each investigative question
- How SIEM enrichment turns a meaningless IP into actionable context

Task 2 - CDN Infrastructure and IP Visibility

The alert from `10.10.15.44` (WKST-FINANCE-04), making a sustained connection to `172.67.153.42` on port 443. IP reputation returns clean. That IP address belongs to Cloudflare, which simultaneously serves traffic for tens of millions of domains. This task covers why IP-based triage is useless here and what to investigate instead.



All logs are pre-ingested in `index=lab`.



The index contains FortiGate firewall logs, Zeek connection records, Sysmon endpoint telemetry, and NetFlow data. Throughout this task, we will use these sources to examine the alert connection, apply ASN enrichment, and surface the behavioral signals that IP reputation cannot.

The CDN Visibility Problem: When WKST-FINANCE-04 connected to `172.67.153.42`, our logs recorded the source IP, destination IP, port, and byte count. What they did not record is which service the traffic was actually destined for - that Cloudflare address simultaneously proxies traffic for millions of distinct services. Our logs show us the CDN hop (**Content Delivery Network** is a geographically distributed network of proxy servers). They cannot show us what is behind it. This is why IP reputation returns clean, and blocking is not an option. The IP is not malicious. It is shared infrastructure. Detection requires a different approach.

Why IP-Based Monitoring Fails Against CDNs: Traditional IP reputation was built on a simpler assumption: one IP, one organization. CDNs invalidated that entirely. A single Cloudflare anycast address simultaneously proxies traffic for millions of distinct services, which is why no reputation feed will ever flag it, as blocking it

would take down legitimate access for all of them. The four CDN providers we will encounter most often in enterprise traffic:

CDN Provider	ASN	Representative IP Ranges
Cloudflare	AS13335	173.245.48.0/20, 103.21.244.0/22, 103.22.200.0/22, 103.31.4.0/22, 141.101.64.0/18, 108.162.192.0/18, 190.93.240.0/20, 188.114.96.0/20, 197.234.240.0/22, 198.41.128.0/17, 162.158.0.0/15, 104.16.0.0/13, 104.24.0.0/14, 172.64.0.0/13, 131.0.72.0/22 — full list (opens in new tab).
Fastly	AS54113	151.101.0.0/16
Akamai	AS16625	23.32.0.0/11
AWS CloudFront	AS16509	13.32.0.0/15, 52.84.0.0/15

When we see these ASNs during an investigation, IP-based triage is off the table. We need to shift to a different set of signals. An **ASN (Autonomous System Number)** is a unique globally assigned identifier used to distinguish a collection of IP networks managed by a single organization (such as an ISP, cloud provider, or enterprise) under a unified routing policy.

How Attackers Exploit CDN Infrastructure: Attackers exploit the same properties that make CDNs useful: shared infrastructure, clean reputation, and encrypted traffic. Two techniques appear consistently across enterprise incidents.

1) Domain Fronting: Domain fronting is an evasion technique that disguises the true destination of an HTTPS request by exploiting how Content Delivery Networks (CDNs) and multi-tenant cloud providers route traffic. Domain fronting ([MITRE ATT&CK T1090.004](#)) exploits the gap between the TLS SNI field (The **TLS SNI (Server Name Indication) field** is an extension to the Transport Layer Security protocol that allows a client (e.g., a web browser) to specify the destination hostname it wants to connect to during the initial network handshake) (which advertises a legitimate hostname like `www.microsoft.com`) and the HTTP Host header inside the encrypted session, which routes traffic to attacker-controlled infrastructure. Every observable indicator points to a trusted domain while the actual C2 traffic hides inside the encrypted payload. [APT29](#) used this extensively against Google App Engine during 2016-2018; [Lotus Blossom](#) continues to exploit

Fastly infrastructure after Cloudflare and AWS closed the technique on their platforms.

2) CDN Tunneling and Worker Abuse: Where domain fronting has been restricted, attackers have moved to Cloudflare Workers and Cloudflare Tunnel, exposing C2 services through `*.workers.dev` and `*.trycloudflare.com`, both domains **allowlisted** by most content filters. BlackWater Cloudflare Workers used Cloudflare Workers as a C2 relay; SerpentineCloud (2025) routes C2 through Cloudflare Tunnel endpoints in organizations that had **allowlisted** `*.trycloudflare.com`. **CDN Tunneling** is a network evasion technique where a user or threat actor routes arbitrary network protocols (such as SSH, SOCKS proxies, or custom C2 traffic) through a Content Delivery Network (CDN) by encapsulating that traffic inside standard, legitimate HTTPS connections.

The Investigative Pivot: What to Look at When IP Is Meaningless:

1) ASN Enrichment: ASN Enrichment (Autonomous System Number Enrichment) is the process of appending network ownership, infrastructure, and reputation context to raw IP addresses in log data or threat telemetry. Instead of viewing an IP address (e.g., `185.220.101.5`) in isolation, ASN enrichment maps it to its governing network (e.g., `AS205100`), revealing the organization, ISP, cloud provider, or hosting facility that controls the infrastructure.

Let's get a picture of where all outbound traffic is actually going. We will use the `asn_lookup` table, which enriches each destination IP with its ASN, organization name, traffic category, and risk tier at query time. ASN enrichment does not reveal which domain is behind a CDN IP address. What it tells us is the type of organization that operates the destination infrastructure. Traffic to Cloudflare CDN is expected. Traffic to Bulletproof Hosting or a Tor exit node requires immediate attention, regardless of IP reputation. This means we can also apply today's threat intelligence to logs ingested months ago, without re-ingesting them.

`asn_lookup` **ASN Enrichment** Instead of showing just a raw IP address in your logs, this lookup enriches the log data by mapping destination IP addresses to network infrastructure information.

```
index=lab sourcetype=fortigate_traffic
| lookup asn_lookup network AS dstip OUTPUT dst_asn_org dst_category dst_risk
```

```
stats count by dst_category dst_asn_org
sort -count
```

New Search Save As Create Table View Close

```
1 index=lab sourcetype=fortigate_traffic
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn_org dst_category dst_risk
3 | stats count by dst_category dst_asn_org
4 | sort -count
```

✓ 18,187 events (before 4/20/26 5:48:10.000 AM) No Event Sampling

Events Patterns **Statistics (35)** Visualization

100 Per Page Format Preview

dst_category	dst_asn_org	count
Unknown	Unknown	18187
CDN	Unknown	10288
CDN	Cloudflare Inc.	7501
Unknown	Cloudflare Inc.	7501
Cloud Provider	Unknown	5859
Cloud Provider	Microsoft Corporation	3861
Unknown	Microsoft Corporation	2317
Cloud Provider	Google LLC	2016
Unknown	Google LLC	2016
CDN	Fastly Inc.	1268
Unknown	Fastly Inc.	1268

The output shows CDN and cloud traffic making up the bulk of the results, as expected. What we are looking for are the outliers: any Bulletproof Hosting or Tor exit nodes sitting in that list. Those are the connections IP reputation missed. The ASN lookup caught them. With the overall picture established, let's now examine the specific connection from our opening alert and start with the raw log:

```
index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42
| table _time srcip dstip proto sentbyte rcvbyte
| sort _time | head 5
```

New Search Save As Create Table View Close

```
1 index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42
2 | table _time srcip dstip proto sentbyte rcvbyte
3 | sort _time | head 5
```

✓ 4,486 events (before 4/16/26 5:50:17.000 PM) No Event Sampling

Events (4,486) Patterns **Statistics (5)** Visualization

100 Per Page Format Preview

_time	srcip	dstip	proto	sentbyte	rcvbyte
2026-03-07 08:54:30	10.10.15.44	172.67.153.42		109633	973325
2026-03-07 09:45:18	10.10.15.44	172.67.153.42		147456	712323
2026-03-07 12:14:23	10.10.15.44	172.67.153.42		163475	37671
2026-03-07 14:57:36	10.10.15.44	172.67.153.42		138547	101085
2026-03-07 16:51:38	10.10.15.44	172.67.153.42		260972	468160

As we can see, the raw log gives us a source IP, a destination IP, a protocol number, and byte counts. `172.67.153.42` alone tells us nothing: no signal to escalate, no signal to close. Now let's apply ASN enrichment to the same record:

```
index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42
| lookup asn_lookup network AS dstip OUTPUT dst_asn_org dst_category
| table _time srcip dstip proto sentbyte rcvbyte dst_asn_org dst_category
| sort _time | head 5
```

New Search

Save As Create Table View Close

1 index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn_org dst_category
3 | table _time srcip dstip proto sentbyte rcvbyte dst_asn_org dst_category
4 | sort _time | head 5

4,486 events (before 4/16/26 5:22:34.000 PM) No Event Sampling

Events (4,486) Patterns Statistics (5) Visualization

100 Per Page Format Preview

_time	srcip	dstip	proto	sentbyte	rcvbyte	dst_asn_org	dst_category
2026-03-07 08:54:30	10.10.15.44	172.67.153.42	17	109633	973325	Cloudflare Inc. Unknown	CDN Unknown
2026-03-07 09:45:18	10.10.15.44	172.67.153.42	17	147456	712323	Cloudflare Inc. Unknown	CDN Unknown
2026-03-07 12:14:23	10.10.15.44	172.67.153.42	17	163475	37671	Cloudflare Inc. Unknown	CDN Unknown
2026-03-07 14:57:36	10.10.15.44	172.67.153.42	17	138547	101085	Cloudflare Inc. Unknown	CDN Unknown
2026-03-07 16:51:38	10.10.15.44	172.67.153.42	17	268972	468160	Cloudflare Inc. Unknown	CDN Unknown

Looking at the output, `172.67.153.42` is identified as a Cloudflare CDN IP address. That single field explains why IP reputation returned clean. This address is shared infrastructure serving tens of millions of services simultaneously, which means we cannot block it, sinkhole it, or match it against reputation feeds. ASN enrichment tells us what type of infrastructure we are dealing with. To identify what is behind it, we need to look at how DNS traffic behaves, which is covered in the next section.

2) Behavioral Baselines: A CDN IP in isolation tells us nothing. What matters is the traffic pattern around it. Three signals can indicate C2 activity through CDN infrastructure. Each comes with caveats worth understanding before escalating:

- **Beaconing regularity:** Connections to the same CDN IP at fixed intervals with no corresponding user activity. Browsers do not generate metronomic outbound traffic to a single destination at consistent sub-minute intervals. This is the most reliable of the three signals.
- **Asymmetric volume:** High outbound byte counts without proportional inbound responses. A CDN serving legitimate content returns substantially more data than it receives. C2 exfiltration inverts this ratio. This signal produces false positives in environments with significant upload activity, such as backup or file sync services, so it should be combined with beaconing frequency before escalation.
- **Off-hours persistence:** Connections continuing overnight or during hours when the host user is inactive. Legitimate CDN requests follow user sessions; C2 beacons are indifferent to whether anyone is logged in. Confirming which process is responsible at scale requires Sysmon EventID 3 deployed across the estate. Without it, we can see something is beaconing, but cannot attribute it to a specific process.

```
index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42
| eval hour=strftime(_time,"%Y-%m-%d %H")
| stats count as per_hour min(sentbyte) as min_b max(sentbyte) as max_b by hour
| sort -per_hour | head 15
```

New Search Save As Create Table View Close

```

1 index=lab sourcetype=fortigate.traffic srcip=10.10.15.44 dstip=172.67.153.42
2 | eval hour=strftime(_time,"%Y-%m-%d %H")
3 | stats count as per_hour min(sentbyte) as min_b max(sentbyte) as max_b by hour
4 | sort -per_hour | head 15

```

✓ 4,486 events (before 4/16/26 5:40:44.000 PM) No Event Sampling Job Verbose Mode

Events (4,486) Patterns Statistics (15) Visualization

100 Per Page Format Preview

hour	per_hour	min_b	max_b
2026-03-17 20	17	846	409217
2026-03-18 17	17	812	35863
2026-03-19 10	17	805	269701
2026-03-24 08	17	804	211538
2026-03-24 12	17	803	309220
2026-03-27 19	17	821	149942
2026-03-28 17	17	850	158337
2026-03-30 15	17	808	270634
2026-03-31 08	17	849	188238

As we can see, 17 connections every hour, consistent across weeks.

The `min_b` values sit in a tight band around 800 bytes: that is the beacon keepalive. The `max_b` spikes vary significantly, representing data bursts riding alongside the regular keepalive traffic. All three signals are present: fixed-interval beaconing, asymmetric volume spikes, and activity persisting well outside business hours. No browser produces this pattern.

A note on jitter: Cobalt Strike lets operators set a jitter percentage on the beacon interval. A 240-second beacon with 25% jitter fires anywhere between 180 and 300 seconds, making a single connection look irregular. The hourly query above accounts for this: `min_b` and `max_b` capture the full spread within the hour, and the connection count stays stable regardless of how individual intervals shift. A jittered beacon at 240 seconds with 25% jitter still produces roughly 17 connections per hour. Where tighter analysis is needed, add `stddev(sentbyte) as std_b` to the query. A low standard deviation paired with a consistent hourly count tells us we are looking at automated tooling, with or without jitter applied.

Note on process attribution: Identifying the specific process responsible for this traffic requires endpoint telemetry, such as Sysmon EventID 3, deployed on the host. Without it, we can see something is beaconing, but cannot determine what. Task 5 covers this in full.

Traditional CDN Detection: Enforced Internal DNS: The most reliable traditional method for identifying what is behind a CDN IP is enforced internal DNS. When all DNS traffic routes through a corporate resolver, we can log every domain lookup along with its resolved IP address. A Cloudflare IP alone tells us nothing, but the

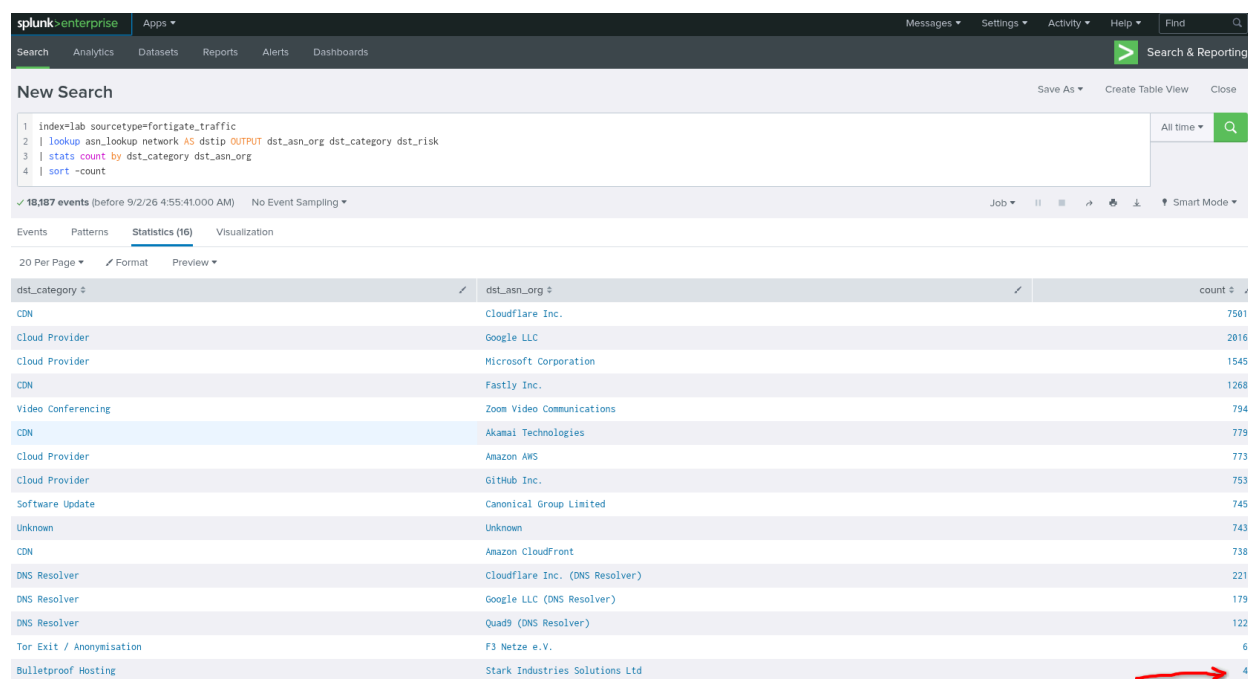
DNS query that preceded it tells us which domain was accessed, giving us the context we need to close the CDN triage gap.

The limitation: when a host switches to DNS over HTTPS, those lookups are encrypted before they reach the internal resolver. The DNS trail disappears, and behavioral signals become our next layer of detection.

Answer the questions below

How many connections in the Fortigate logs have a `dst_category` of **Bulletproof Hosting**?

4



New Search

```
1 index=lab sourcetype=fortigate.traffic
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn_org dst_category dst_risk
3 | stats count by dst_category dst_asn_org
4 | sort -count
```

✓ 18,187 events (before 9/2/26 4:55:41.000 AM) No Event Sampling

Events Patterns **Statistics (16)** Visualization

20 Per Page Format Preview

dst_category	dst_asn_org	count
CDN	Cloudflare Inc.	7501
Cloud Provider	Google LLC	2016
Cloud Provider	Microsoft Corporation	1545
CDN	Fastly Inc.	1268
Video Conferencing	Zoom Video Communications	794
CDN	Akamai Technologies	779
Cloud Provider	Amazon AWS	773
Cloud Provider	GitHub Inc.	753
Software Update	Canonical Group Limited	745
Unknown	Unknown	743
CDN	Amazon CloudFront	738
DNS Resolver	Cloudflare Inc. (DNS Resolver)	221
DNS Resolver	Google LLC (DNS Resolver)	179
DNS Resolver	Quad9 (DNS Resolver)	122
Tor Exit / Anonymisation	F3 Netze e.V.	6
Bulletproof Hosting	Stark Industries Solutions Ltd	4

Looking at the hourly beaconing results, What is the minimum `min_b` value in the hourly results, representing the beacon keepalive size in bytes?

800

As explained above

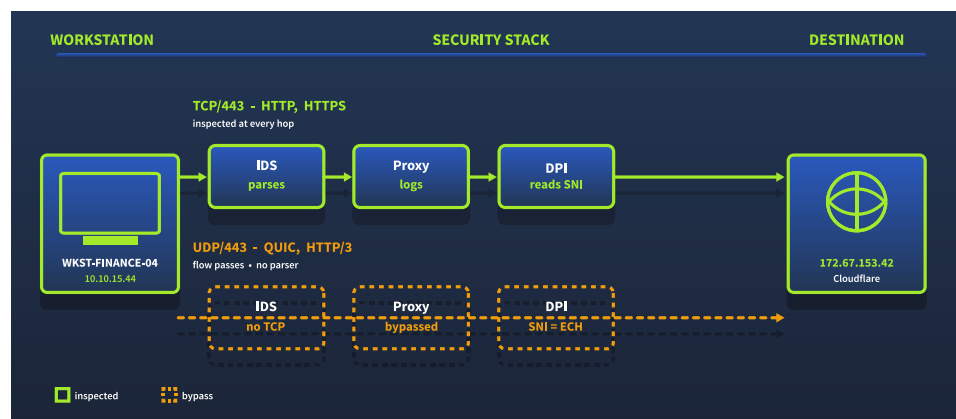
Task 3 - QUIC and the End of TCP Assumptions

Traditional network security stacks built around TCP, port 443, and TLS proxying can no longer monitor modern web traffic effectively. HTTP/3 relies on UDP and QUIC, causing legacy TCP-focused detection tools, proxies, and NetFlow filters to miss valid web traffic.

QUIC (standardized in RFC 9000) is a modern transport-layer network protocol designed to replace TCP for faster, more secure internet connections. Originally created by Google and now managed by the IETF, QUIC serves as the underlying transport protocol for **HTTP/3**.

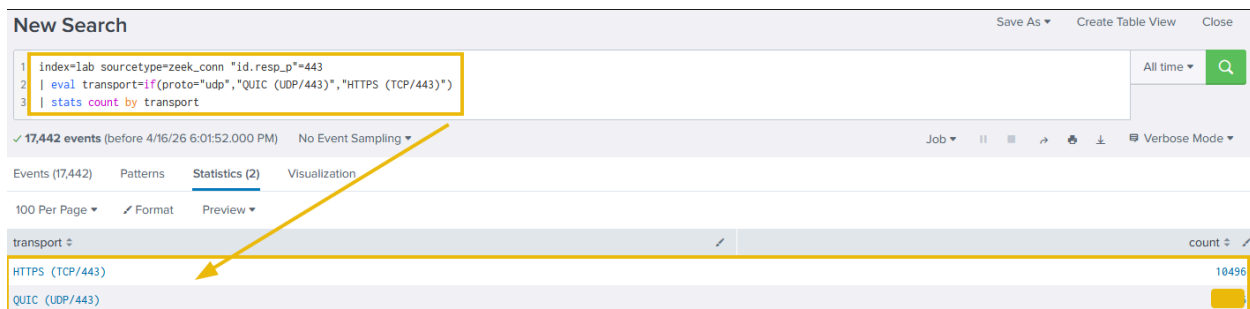
QUIC (RFC 9000) runs HTTP/3 over UDP port 443 with built-in TLS 1.3, carrying ~35% of web traffic while bypassing legacy TCP inspection.

RFC 9000 is the official Internet Engineering Task Force (IETF) standard that defines **QUIC**, a secure, multiplexed transport protocol built on top of UDP. It serves as the foundational transport layer for HTTP/3.



IDS signatures on TCP/443. A rule written as `alert TCP any any -> any 443` will never fire on a QUIC connection. The protocol is UDP, so the rule silently misses it. To better understand, let's run the following search query:

```
index=lab sourcetype=zeek_conn "id.resp_p"=443
| eval transport=if(proto="udp","QUIC (UDP/443)","HTTPS (TCP/443)")
| stats count by transport
```



As shown in the output, approximately 22% of all traffic on port 443 is QUIC. That means an `alert TCP` rule is silently missing nearly a quarter of all encrypted outbound sessions, without a single alert firing.

Proxy inspection: Enterprise web proxies terminate TCP connections to perform TLS inspection. QUIC runs over UDP. It bypasses the proxy entirely. We are inspecting the TCP fallback while QUIC sessions go uninspected.

Detecting QUIC: The most reliable signal here is straightforward: `UDP/443` in our flow logs means QUIC. No other common enterprise application uses UDP/443. At the firewall, we work through four steps:

1. Log all `protocol=UDP, dst_port=443` flows
2. Enrich the destination with ASN context
3. Investigate any session destined for a non-CDN, non-cloud IP
4. Flag sessions with unusually long duration or high outbound volume

Now let's run the following search query to look for QUIC sessions showing the kind of duration and volume that no browser would produce:

```
index=lab sourcetype=zeek_conn service=quic
| lookup asn_lookup network AS "id.resp_h" OUTPUT dst_asn_org
dst_category
| where duration > 3600
| table _time "id.orig_h" "id.resp_h" duration orig_bytes res
p_bytes dst_asn_org
```

New Search Save As Create Table View Close

```

1 index=lab sourcetype=zeek_conn service=quic
2 | lookup asn_lookup network AS "id.resp_h" OUTPUT dst_asn_org dst_category
3 | where duration > 3600
4 | table _time "id.orig_h" "id.resp_h" duration orig_bytes resp_bytes dst_asn_org

```

✓ 1 event (before 4/16/26 6:05:33.000 PM) No Event Sampling

Events (1) Patterns Statistics (1) Visualization

100 Per Page Format Preview

_time	id.orig_h	id.resp_h	duration	orig_bytes	resp_bytes	dst_asn_org
2026-04-02 02:47:00	10.10.15.44	172.67.153.42		847823104	2897152	Cloudflare Inc. Unknown

Looking at the output, one session stands out immediately: 4 hours 12 minutes, 847 MB outbound, 2 MB inbound. The destination is CDN, but the duration and byte asymmetry are not typical of browser behavior. The reason there was no proxy log for it: **it was QUIC, not TCP.**

Detection and Mitigation: Major NGFW and IPS platforms—including Palo Alto, Fortinet, and Check Point—support native UDP/443 QUIC parsing. Enabling and tuning this feature restores full inspection coverage without impacting traffic or requiring architectural policy changes. If our platform does not support QUIC inspection, we face a genuine trade-off. QUIC now carries roughly 35% of global web traffic, so blocking UDP/443 is not a casual decision. That said, in environments where all encrypted traffic must pass through a proxy for inspection, allowing uninspected QUIC sessions is the worst of the two options. Every major browser negotiates QUIC via the **Alt-Svc** (Alternative Service) header and falls back to HTTP/2 over TCP automatically when UDP/443 is unreachable. Users see no broken sites. The trade-off is a small latency increase on sessions that would have used QUIC. Where full proxy visibility is a hard requirement, blocking outbound UDP/443 is a well-understood policy deployed across many enterprise environments.

Answer the questions below

Run the transport breakdown query. How many port 443 sessions in the Zeek logs use QUIC (UDP/443)?

6946

splunk>enterprise Apps Messages Settings Activity Help Find

Search Analytics Datasets Reports Alerts Dashboards Search & Reporting

New Search

Save As Create Table View Close

```

1 index=lab sourcetype=zeek_conn "id.resp_p"=443
2 | eval transport=if(proto="udp","QUIC (UDP/443)","HTTPS (TCP/443)")
3 | stats count by transport

```

All time

✓ 17,442 events (before 9/2/26 5:05:17.000 AM) No Event Sampling Job

Events Patterns **Statistics (2)** Visualization

20 Per Page Format Preview

transport	count
HTTPS (TCP/443)	10496
QUIC (UDP/443)	6946

Run the anomalous QUIC session query. What is the duration in seconds of the session that exceeds one hour?

15180

splunk>enterprise Apps Messages Settings Activity Help Find

Search Analytics Datasets Reports Alerts Dashboards Search & Reporting

New Search

Save As Create Table View Close

```

1 index=lab sourcetype=zeek_conn service=quic
2 | lookup asn_lookup network AS "id.resp_h" OUTPUT dst_asn_org dst_category
3 | where duration > 3600
4 | table _time "id.orig_h" "id.resp_h" duration orig_bytes resp_bytes dst_asn_org

```

All time

✓ 1 event (before 9/2/26 5:06:06.000 AM) No Event Sampling Job

Events Patterns **Statistics (1)** Visualization

20 Per Page Format Preview

_time	id.orig_h	id.resp_h	duration	orig_bytes	resp_bytes	dst_asn_org
2026-04-02 02:47:00	10.10.15.44	172.67.153.42	15180.0	847823104	2097152	Cloudflare Inc.

Task 4 - Encrypted Protocols and Signal Loss

Modern encryption standards have effectively blinded legacy passive monitoring by wrapping plaintext DNS (UDP/53) in DoH and hiding the TLS SNI target via Encrypted Client Hello (ECH). Between them, DNS over HTTPS (DoH) and

Encrypted Client Hello (ECH) removed two signals analysts had relied on for decades. This task covers what each protocol does to our visibility and the detection techniques that compensate for it.

- **DoH (DNS over HTTPS):** Encrypts standard DNS queries by wrapping them inside HTTPS (port 443) traffic, hiding domain lookups from network-level passive eavesdropping on UDP port 53.
- **ECH (Encrypted Client Hello):** An extension to TLS 1.3 that encrypts the initial Client Hello handshake—specifically the Server Name Indication (SNI)—preventing intermediate network sensors from seeing which domain name a client is trying to reach.



Part a: DNS Over HTTPS

Why DNS Used to Be So Useful: Plaintext DNS (UDP/53) provided essential security visibility—enabling C2 beaconing detection, DGA analysis, threat feed matching, sinkholing, and full host audit logging—that modern encrypted standards now obscure. The SolarWinds breach ([SUNBURST, December 2020](#)) compromised approximately 18,000 organizations. Investigators identified the malware, in part, through DNS logs. SUNBURST encoded victim identifiers into DGA subdomain queries at 120-minute intervals. With DoH, that detection path is significantly harder.

What DoH Does to Visibility: DoH ([RFC 8484](#)) encrypts DNS queries inside HTTPS, sending them directly to an external resolver such as `1.1.1.1` or `8.8.8.8`. From the network, it looks identical to any other HTTPS request. What disappears:

C2 detection via DNS timing, DGA detection, threat feed matching, DNS sinkholing, and the DNS audit trail.

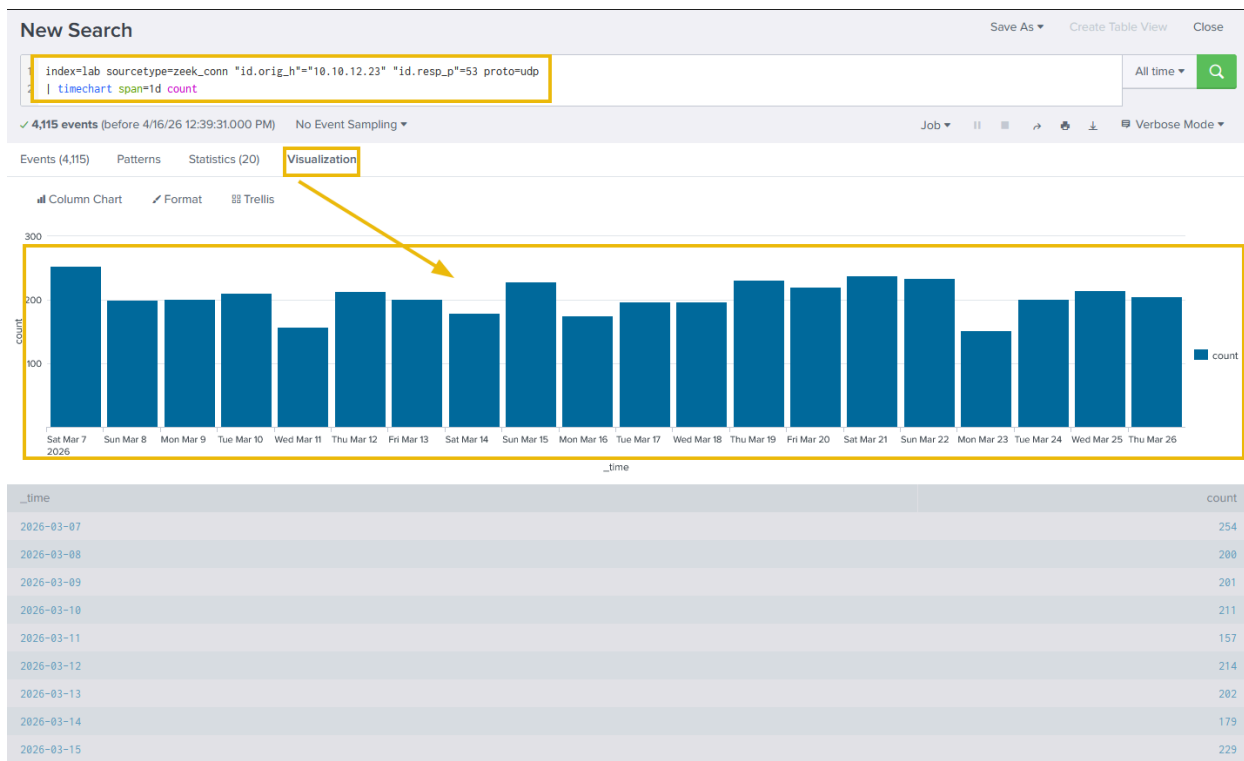
The Silent Host Pattern: When a workstation switches to DoH, it stops appearing in UDP/53 logs entirely. A host that generated hundreds of DNS queries per day for months and then produces zero is a detectable anomaly, even though we can no longer see what it is resolving. Let's look across all internal hosts and find any that have gone silent:

```
index=lab sourcetype=zeek_conn "id.resp_p"=53 proto=udp  
| timechart span=1d count by "id.orig_h"
```



Looking at the time chart, every internal workstation shows consistent daily DNS traffic, except one. After March 26, `10.10.12.23` (WKST-MKTG-07) drops to zero and stays there. Let's narrow it to that host and confirm the exact switch date:

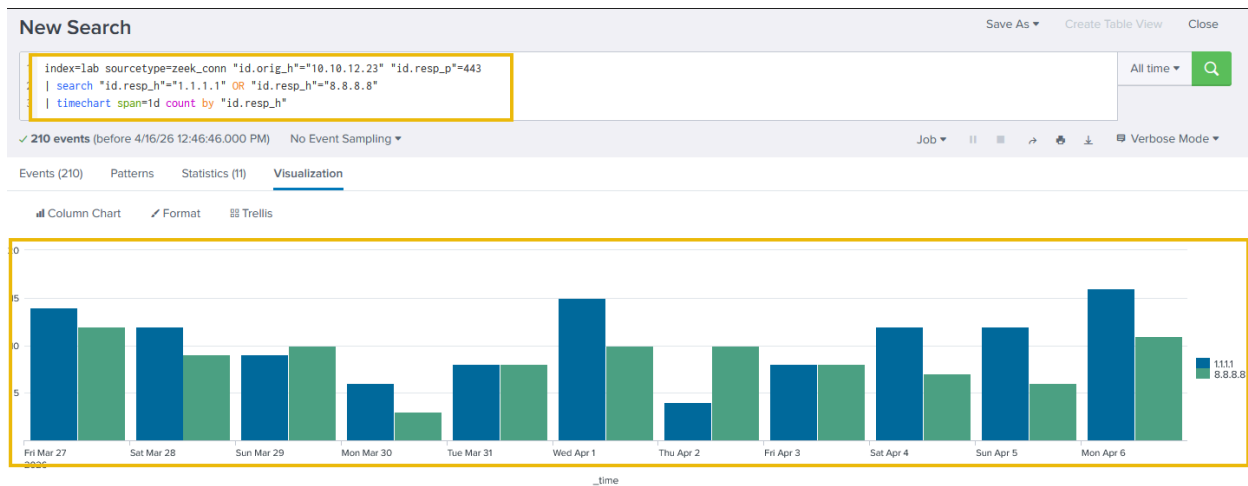
```
index=lab sourcetype=zeek_conn "id.orig_h"="10.10.12.23" "id.  
resp_p"=53 proto=udp  
| timechart span=1d count
```



As we can see, WKST-MKTG-07's UDP/53 traffic drops completely from March 27, pinpointing the exact date DoH took over on this host. Now let's confirm DoH is actually what replaced it:

Detection and Mitigation: Monitor Known DoH Resolver IPs: When UDP/53 stops, TCP/443 connections to known DoH resolvers (`1.1.1.1` , `8.8.8.8` , `9.9.9.9` , or `149.112.112.112`) should appear in its place. Let's check:

```
index=lab sourcetype=zeek_conn "id.orig_h"="10.10.12.23" "id.
resp_p"=443
| search "id.resp_h"="1.1.1.1" OR "id.resp_h"="8.8.8.8"
| timechart span=1d count by "id.resp_h"
```



Looking at the output, connections to 1.1.1.1:443 appear from March 27 onwards, with zero before that date. The two signals confirm each other: UDP/53 drops exactly when TCP/443 to Cloudflare DoH begins. This confirms DoH is in use. It does not show us what the host is resolving. Those lookups are now encrypted. The only remaining path to hostname visibility on this host is endpoint telemetry.

Part b: Encrypted Client Hello (ECH)

TLS Server Name Indication (SNI) historically sent the destination hostname in plaintext during the TLS handshake, even in encrypted sessions. Security teams relied on this for URL filtering, threat feed matching, and traffic classification. ECH (RFC draft) encrypts the entire ClientHello, including SNI. A network observer now sees only the destination IP and port. The hostname is gone. Cloudflare has enabled ECH by default across its network, covering roughly 20% of global web traffic.

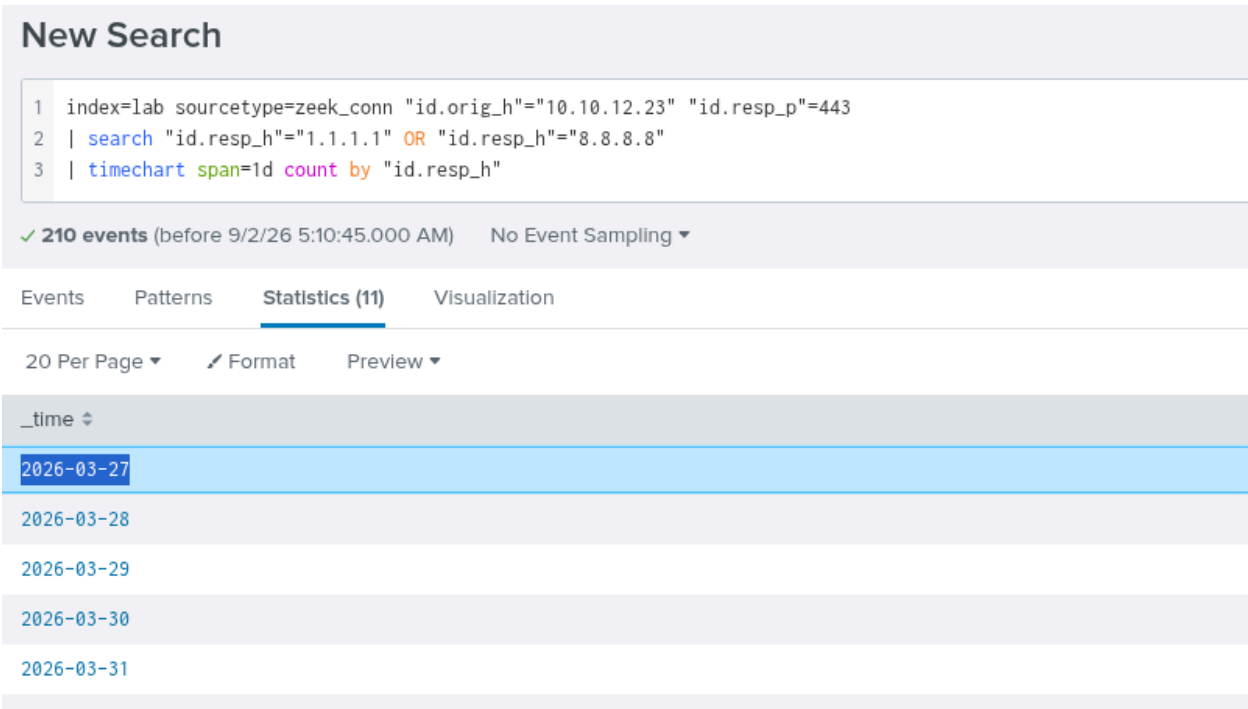
Working Around the Blind Spot

- **JA4 fingerprinting:** Fingerprints the TLS handshake parameters instead of the hostname. Consistent across a malware family, even when SNI is hidden.
- **Certificate Transparency logs:** Every certificate is publicly logged. Query `crt.sh` with a suspected IP or domain to find the hostname even when ECH hides it.
- **Endpoint telemetry:** The process knows what it requested. Sysmon EventID 22 captures DNS lookups before they are encrypted.

Answer the questions below

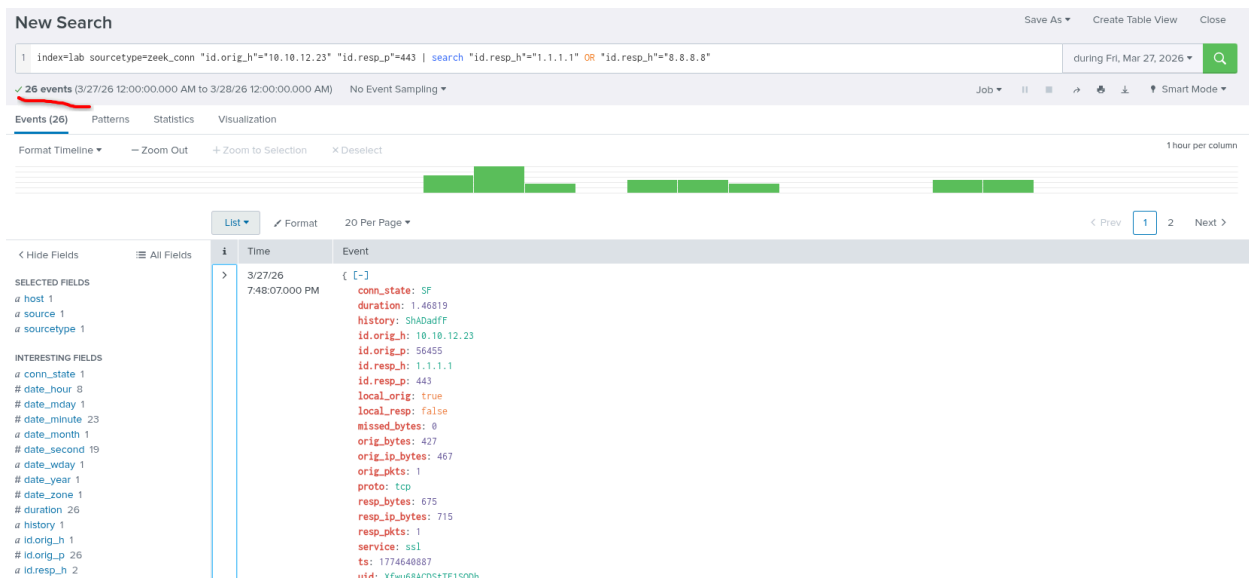
Run the all-hosts DNS timechart below. On what date does **WKST-MKTG-07** (10.10.12.23) first appear with zero UDP/53 queries? (Answer Format: YYYY-MM-DD)

2026-03-27



From the DoH confirmation query results, how many total DoH connections does **WKST-MKTG-07** make on 2026-03-27 across both resolvers?

26



Task 5 - The Log Enrichment Hierarchy

Firewall logs lack process-level context, providing only network-layer metadata (IPs, ports, byte counts) while omitting the host process ID, path, or parent process responsible for the traffic.

The Fidelity-Scalability Trade-off: Every log source sits somewhere between two opposing properties: **fidelity** (how complete the information is) and **scalability** (how practical it is to retain and query at enterprise scale). Raw PCAP captures every byte of every packet, but is expensive to store beyond short retention windows. NetFlow records are tiny by comparison, but they cannot show us what was in the payload. Selecting the right source means knowing where each one sits on this spectrum.

Log Source	What It Answers	Fidelity	Scalability
NetFlow / IPFIX	Who talked to whom, when, how long, how much data	Flow metadata only	Enterprise-scale: years of retention practical
FortiGate / NGFW logs	Was the connection allowed? What URL? Which user?	URL, user, policy decision	Managed: dependent on proxy/SSL inspection

Log Source	What It Answers	Fidelity	Scalability
Sysmon EventID 3	Which process on which host initiated this connection?	Process-attributed, full endpoint context	Requires EDR deployment on each host
Raw PCAP	What were the exact bytes exchanged?	Maximum: full payload	Impractical beyond short retention windows
SIEM enrichment layer	What do we know about the destination IP?	Context appended at query time	No additional storage cost

Matching Sources to Questions: Let's examine the key investigative questions and the log sources that answer each one.



The Same Connection Through Four Lenses: Let's see these differences in practice. We will use the suspicious connection from **WKST-FINANCE-04** (10.10.15.44) to **172.67.153.42**. We will query it across four sourcetypes. Each answers a different investigative question and also has a ceiling.

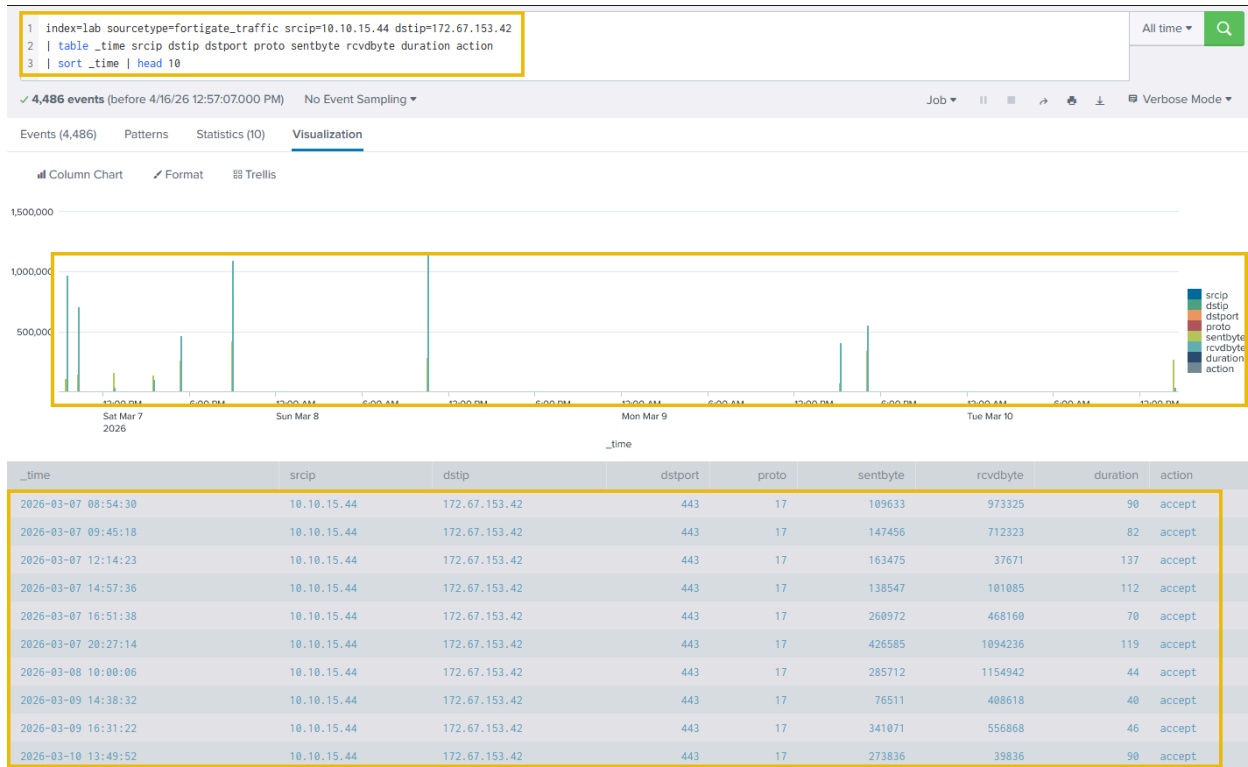
The Firewall View: Let's start with the FortiGate. Was this connection allowed, and what are the flow basics?

```
index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42
| table _time srcip dstip dstport proto sentbyte rcvdbyte dur
```

```

action action
| sort _time | head 10

```



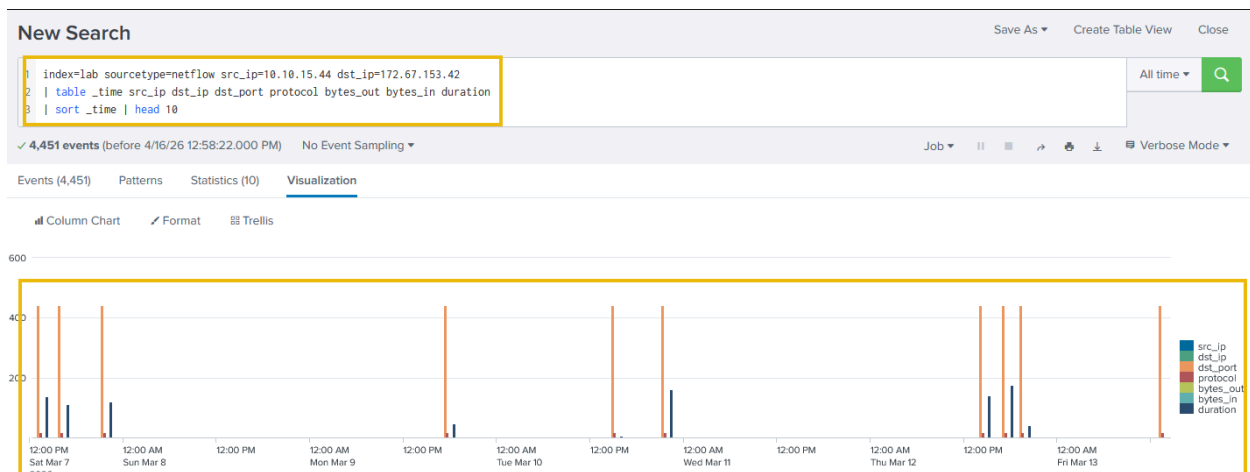
As we can see, UDP (proto 17) on port 443 is accepted by policy, with a rate of 1 every 4 minutes from March 17. The FortiGate confirms that the connection exists and provides byte counts and the protocol. It cannot tell us which process is responsible.

The NetFlow View: NetFlow gives us independent corroboration: a second source confirming the flow from a different network vantage point.

```

index=lab sourcetype=netflow src_ip=10.10.15.44 dst_ip=172.6
7.153.42
| table _time src_ip dst_ip dst_port protocol bytes_out bytes
_in duration
| sort _time | head 10

```



Looking at the output, the result is structurally identical to the FortiGate: UDP on port 443, consistent byte counts, repeating every four minutes. Two independent network-layer sources agree. Neither moves us closer to process attribution. That question cannot be answered solely from network-layer data.

The Zeek View: Zeek gives us something FortiGate and NetFlow cannot: application-layer protocol identification. Both previous sources confirmed the presence of a UDP flow on port 443. Zeek tells us what that flow actually is.

```

index=lab sourcetype=zeek_conn "id.orig_h"="10.10.15.44" "id.
resp_h"="172.67.153.42"
| table _time "id.orig_h" "id.resp_h" proto service duration
orig_bytes resp_bytes
| sort _time | head 10

```

New Search

```

1 index=lab sourcetype=zeek_conn "id.orig_h"="10.10.15.44" "id.resp_h"="172.67.153.42"
2 | table _time "id.orig_h" "id.resp_h" proto service duration orig_bytes resp_bytes
3 | sort _time | head 10

```

✓ 4,486 events (before 6/3/26 8:25:02.000 PM) No Event Sampling

Events Patterns Statistics (10) Visualization

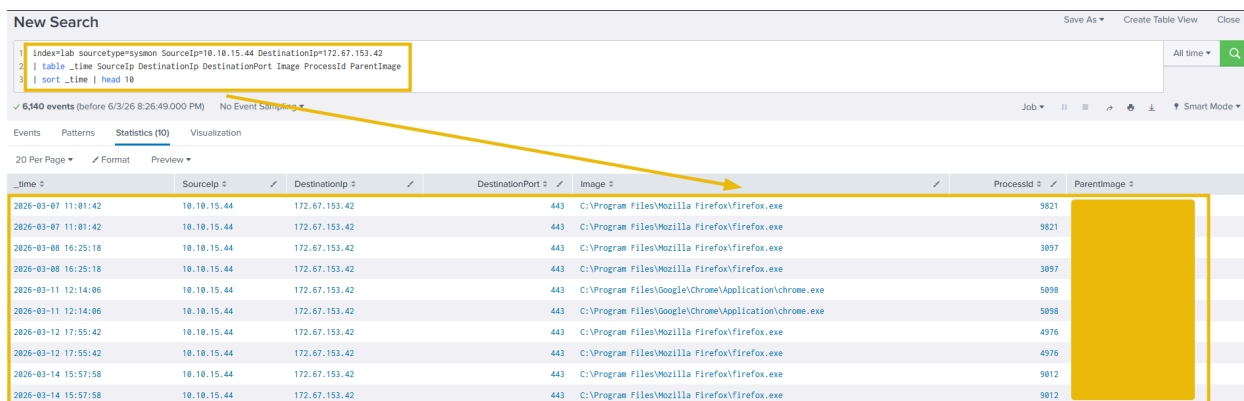
20 Per Page Format Preview

_time	id.orig_h	id.resp_h	proto	service	duration	orig_bytes	resp_bytes
2026-03-07 08:54:38	10.10.15.44	172.67.153.42	udp	quic	98.0	109533	973325
2026-03-07 09:45:18	10.10.15.44	172.67.153.42	udp	quic	82.0	147456	712323
2026-03-07 12:14:23	10.10.15.44	172.67.153.42	udp	quic	137.0	163475	37671
2026-03-07 14:57:36	10.10.15.44	172.67.153.42	udp	quic	112.0	138547	181885
2026-03-07 16:51:38	10.10.15.44	172.67.153.42	udp	quic	78.0	268972	468168
2026-03-07 20:27:14	10.10.15.44	172.67.153.42	udp	quic	119.0	426585	1094236
2026-03-08 10:00:06	10.10.15.44	172.67.153.42	udp	quic	44.0	285712	1154942
2026-03-09 14:38:32	10.10.15.44	172.67.153.42	udp	quic	40.0	76511	488618
2026-03-09 16:31:22	10.10.15.44	172.67.153.42	udp	quic	46.0	341071	556868
2026-03-10 13:49:52	10.10.15.44	172.67.153.42	udp	quic	90.0	273836	39836

Looking at the output, the `service` field returns `quic` across every session, and `proto` confirms UDP throughout. This answers a question the previous two sources left open: there is no proxy log for this connection because QUIC runs over UDP and bypasses proxy inspection entirely. Three network-layer sources now agree on the flow. Zeek is the first to tell us what transport it is running on.

The Sysmon View: Sysmon EventID 3 is the process-attributed network connection log. Every TCP and UDP connection generates a record containing the process name (`Image`), PID, parent process (`ParentImage`), and full connection details. These fields do not exist anywhere in the network layer. The query structure for process attribution:

```
index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
| table _time SourceIp DestinationIp DestinationPort Image ProcessId ParentImage
| sort _time | head 10
```



New Search

1 index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
2 | table _time SourceIp DestinationIp DestinationPort Image ProcessId ParentImage
3 | sort _time | head 10

6,140 events (before 6/3/26 8:26:49:000 PM) No Event Sampling

Events Patterns Statistics (10) Visualization

_time	SourceIp	DestinationIp	DestinationPort	Image	ProcessId	ParentImage
2026-03-07 11:01:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9821	
2026-03-07 11:01:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9821	
2026-03-08 16:25:18	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	3097	
2026-03-08 16:25:18	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	3097	
2026-03-11 12:14:06	10.10.15.44	172.67.153.42	443	C:\Program Files\Google\Chrome\Application\chrome.exe	5098	
2026-03-11 12:14:06	10.10.15.44	172.67.153.42	443	C:\Program Files\Google\Chrome\Application\chrome.exe	5098	
2026-03-12 17:55:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	4976	
2026-03-12 17:55:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	4976	
2026-03-14 15:57:58	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9012	
2026-03-14 15:57:58	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9012	

The `Image` field returns the full path to the process executable. `ProcessId` stays consistent for the lifetime of a process. A single PID appearing across hundreds of records spanning multiple days tells us the same process has been running continuously. `ParentImage` tells us what launched it: a browser launched by `explorer.exe` is expected; a script interpreter launched by a document application is not. To surface which process is responsible for the most connections to a given destination:

```
index=lab sourcetype=sysmon DestinationIp=172.67.153.42
| stats count by Image
| sort -count
```

New Search

1 index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
 2 | table _time SourceIp DestinationIp DestinationPort Image ProcessId ParentImage
 3 | sort _time | head 10

6,140 events (before 6/3/26 8:26:49.000 PM) No Event Sampling

Events Patterns Statistics (10) Visualization

20 Per Page Format Preview

_time	SourceIp	DestinationIp	DestinationPort	Image	ProcessId	ParentImage
2026-03-07 11:01:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9821	
2026-03-07 11:01:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9821	
2026-03-08 16:25:18	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	3897	
2026-03-08 16:25:18	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	3897	
2026-03-11 12:14:06	10.10.15.44	172.67.153.42	443	C:\Program Files\Google\Chrome\Application\chrome.exe	5098	
2026-03-11 12:14:06	10.10.15.44	172.67.153.42	443	C:\Program Files\Google\Chrome\Application\chrome.exe	5098	
2026-03-12 17:55:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	4976	
2026-03-12 17:55:42	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	4976	
2026-03-14 15:57:58	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9012	
2026-03-14 15:57:58	10.10.15.44	172.67.153.42	443	C:\Program Files\Mozilla Firefox\firefox.exe	9012	

The count comparison is the signal. Browser processes making incidental CDN hits show tens of connections. A process running automated outbound connections shows thousands of connections. The volume gap between the two draws our attention. We apply both of these queries in Task 7, where they surface the pivotal finding of the WKST-FINANCE-04 investigation.

Note: Sysmon EventID 3 is only available if Sysmon is deployed on the endpoint. In practice, many large organizations have Sysmon on fewer than 20% of their estate. Knowing which investigative paths close when Sysmon is absent is part of working the hierarchy effectively.

Answer the questions below

Run the process count query against `172.67.153.42`. Which process is responsible for the most connections to this destination?

C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE

New Search

Save AsCreate Table ViewClose

1 index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42

2 | table _time SourceIp DestinationIp DestinationPort Image ProcessId ParentImage

3 | sort _time | head 10

during Fri, Mar 27, 2026

✓ 288 events (3/27/26 12:00:00.000 AM to 3/28/26 12:00:00.000 AM) No Event Sampling

Job || Settings Add Remove Smart Mode

EventsPatternsStatistics (10)Visualization

20 Per PageFormatPreview

_time	SourceIp	DestinationIp	DestinationPort	Image	ProcessId	ParentImage
2026-03-27 08:04:04	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	
2026-03-27 08:04:04	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	C:\Windows\explorer.exe
2026-03-27 08:08:04	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	
2026-03-27 08:08:04	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	C:\Windows\explorer.exe
2026-03-27 08:19:41	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	
2026-03-27 08:19:41	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	C:\Windows\explorer.exe
2026-03-27 08:23:31	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	
2026-03-27 08:23:31	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	C:\Windows\explorer.exe
2026-03-27 08:28:27	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	
2026-03-27 08:28:27	10.10.15.44	172.67.153.42	443	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	C:\Windows\explorer.exe

Task 6 - SIEM Enrichment in Practice

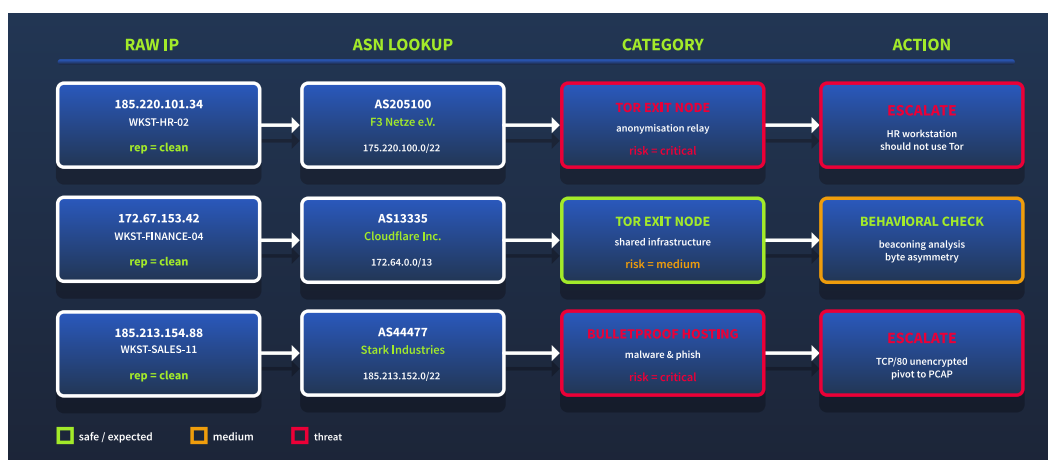
The connection is to 185.220.101.34 , and we are seconds away from closing the ticket. Every threat intelligence feed returns the same result: no malware associations, no C2 history, no blocklist entries. That IP belongs to AS205100, F3 Netze e.V., a Tor relay operator. One enrichment field is enough to move this ticket from routine closure to immediate escalation. The data was in the logs; the context was what we lacked. ASN enrichment adds that context at query time, not at ingestion. A FortiGate log from six months ago can be enriched with intelligence we only have today, with no re-ingestion required.

ASN Categories Reference: Enrichment results only make sense if we know what each category means. The table below maps categories to analyst actions.

Category	Examples	Analyst Action
CDN	Cloudflare (AS13335), Fastly (AS54113), Akamai (AS16625), CloudFront (AS16509)	Baseline check only. IP-based triage is not useful here.
Cloud Provider	AWS (AS16509), Azure (AS8075), GCP (AS15169)	Determine specific service if volume or behavior is anomalous.
DNS Resolver	Cloudflare DoH (AS13335 1.1.1.x), Google DNS (AS15169 8.8.x.x)	Confirm whether the host should use an external DNS server.
Bulletproof Hosting	Stark Industries Solutions (AS44477)	Immediate escalation. Routinely associated with malware hosting

Category	Examples	Analyst Action
		and phishing infrastructure.
Tor Exit / Anonymization	F3 Netze e.V. (AS205100)	Immediate escalation. Employee workstations should not route traffic through Tor exit relays.

The distinction between CDN and Bulletproof Hosting is not about whether the IP address is known to be bad. It is a statement about the type of organization operating it. Traffic to Cloudflare is expected; traffic to Stark Industries requires explanation.



Running ASN Enrichment Against the FortiGate Logs: Let's start by establishing the baseline traffic picture before we look for anomalies:

```

index=lab sourcetype=fortigate_traffic
| lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_o
rg dst_category dst_risk
| stats count by dst_category dst_risk
| sort -count

```

New Search

```

1 index=lab sourcetype=fortigate_traffic
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_org dst_category dst_risk
3 | stats count by dst_category dst_risk
4 | sort -count

```

✓ 10,187 events (before 6/3/26 10:01:00.000 PM) No Event Sampling

Events Patterns Statistics (8) Visualization

20 Per Page Format Preview

dst_category	dst_risk	count
CDN	low	6194
Cloud Provider	low	5087
Unknown	medium	2835
Video Conferencing	low	794
Software Update	low	745
DNS Resolver	low	522
Tor Exit / Anonymisation	high	4
Bulletproof Hosting	high	4

Looking at the output, CDN and cloud dominate as expected. The Bulletproof Hosting and Tor connections stand out immediately: both IPs pass reputation checks, but the ASN category classification surfaces them for what they are.

Step 2: Filter to High-Risk Destinations Only: Now let's cut through the noise and isolate only the connections that require analyst attention:

```

index=lab sourcetype=fortigate_traffic
| lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_org dst_category dst_risk
| where dst_risk="high" OR dst_risk="critical"
| table _time srcip srcname dstip dstport proto sentbyte rcvdb
byte dst_asn_org dst_category dst_risk
| sort _time

```

New Search

```

1 index=lab sourcetype=fortigate_traffic
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_org dst_category dst_risk
3 | where dst_risk="high" OR dst_risk="critical"
4 | table _time srcip srcname dstip dstport proto sentbyte rcvdb
byte dst_asn_org dst_category dst_risk
5 | sort _time

```

✓ 10 events (before 6/3/26 10:02:20.000 PM) No Event Sampling

Events Patterns Statistics (10) Visualization

20 Per Page Format Preview

_time	srcip	srcname	dstip	dstport	proto	sentbyte	rcvdb	dst_asn_org	dst_category	dst_risk
2026-03-22 10:00:00	10.10.11.18	WKST	185.220.101.34	443	6	2841	2650	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:02:00	10.10.11.18	WKST	185.220.101.34	443	6	2956	2890	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:04:00	10.10.11.18	WKST	185.220.101.34	443	6	3102	2700	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:06:00	10.10.11.18	WKST	185.220.101.34	443	6	2778	2600	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:08:00	10.10.11.18	WKST	185.220.101.34	443	6	3045	2980	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:10:00	10.10.11.18	WKST	185.220.101.34	443	6	2901	2750	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-25 13:52:00	10.10.13.67	WKST	185.213.154.88	443	6	29763	74448	Stark Industries Solutions Ltd	Bulletproof Hosting	high
2026-03-25 14:06:00	10.10.13.67	WKST	185.213.154.88	443	6	29545	12777	Stark Industries Solutions Ltd	Bulletproof Hosting	high
2026-03-25 15:52:45	10.10.13.67	WKST	185.213.154.88	443	6	43446	59370	Stark Industries Solutions Ltd	Bulletproof Hosting	high
2026-03-25 17:34:59	10.10.13.67	WKST	185.213.154.88	443	6	28848	27401	Stark Industries Solutions Ltd	Bulletproof Hosting	high

As we can see, two distinct incidents surface: **10.10.11.18** connecting to a Tor exit relay on March 22, and **10.10.13.67** connecting to Stark Industries on March 25.

Step 3: Examine the Tor Exit Connections in Detail: Let's drill into the HR workstation's Tor connections and examine each session:

New Search

Save As

Create Table View

Close

index=lab sourcetype=fortigate_traffic srcip=10.10.11.18 dstip=185.220.101.34

table_time

srcip

dstip

dstport

proto

sentbyte

rcvdbyte

duration

sort_time

All time

6 events (before 4/16/26 1:33:46.000 PM) No Event Sampling

Job

Verbose Mode

Events (6) Patterns **Statistics (6)** Visualization

100 Per Page

Format

Preview

_time	srcip	dstip	dstport	proto	sentbyte	rcvdbyte	duration
2026-03-22 15:26:22	10.10.11.18	185.220.101.34	443	6	53194	119473	113
2026-03-22 19:38:09	10.10.11.18	185.220.101.34	443	6	75460	60857	109
2026-03-22 20:09:45	10.10.11.18	185.220.101.34	443	6	66307	30400	106
2026-03-22 21:25:05	10.10.11.18	185.220.101.34	443	6	22415	28302	52
2026-03-22 22:01:37	10.10.11.18	185.220.101.34	443	6	53760	89034	76
2026-03-22 22:46:09	10.10.11.18	185.220.101.34	443	6	16374	31438	39

185.220.101.34 returns a clean reputation score from most threat intelligence feeds. It is not a flagged C2 IP and appears on no blocklist. The only reason this connection surfaces is ASN enrichment identifying F3 Netze e.V. as a Tor relay operator. Without that enrichment, it would have closed as a false positive.

```
index=lab sourcetype=fortigate_traffic srcip=10.10.13.67 dstip=185.213.154.88
```

```
| table _time srcip dstip dstport proto sentbyte rcvdbyte duration
| sort _time
```

New Search Save As Create Table View Close

```
1 index=lab sourcetype=fortigate_traffic srcip=10.10.13.67 dstip=185.213.154.88
2 | table _time srcip dstip dstport proto sentbyte rcvdbyte duration
3 | sort _time
```

All time Q

✓ 4 events (before 4/16/26 1:36:04.000 PM) No Event Sampling Job Verbose Mode

Events (4) Patterns Statistics (4) Visualization

100 Per Page Format Preview

time	srcip	dstip	dstport	proto	sentbyte	rcvdbyte	duration
2026-03-25 13:52:00	10.10.13.67	185.213.154.88	443	6	29763	74448	24
2026-03-25 14:06:00	10.10.13.67	185.213.154.88	443	6	29545	12777	49
2026-03-25 15:52:45	10.10.13.67	185.213.154.88	443	6	43446	59370	5
2026-03-25 17:34:59	10.10.13.67	185.213.154.88	443	6	28848	27401	60

Looking at the output, there are four connections over one day on TCP/443 to AS44477, a bulletproof hosting provider with a well-documented history in abuse reports. The connections are on TCP port 443. A targeted PCAP capture or FortiGate application log review would be the next step to identify what was exchanged.

Answer the questions below

Run the baseline enrichment query. How many FortiGate connections resolve to a `dst_category` of Tor Exit / Anonymisation?

6

New Search Save As ▾ Create Table View Close

```

1 index=lab sourcetype=fortigate_traffic
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_org dst_category dst_risk
3 | stats count by dst_category dst_risk
4 | sort -count

```

✓ 18,187 events (before 9/2/26 5:24:17.000 AM) No Event Sampling ▾ Job ▾ || ■ ↶ ↷ ⬇ ⬆ Smart Mode ▾

Events Patterns **Statistics (8)** Visualization

20 Per Page ▾ Format Preview ▾

dst_category ▾	dst_risk ▾	count ▾
CDN	low	10286
Cloud Provider	low	5087
Video Conferencing	low	794
Software Update	low	745
Unknown	medium	743
DNS Resolver	low	522
Tor Exit / Anonymisation	high	6
Bulletproof Hosting	high	4

Run the high-risk filter query. What is the `srcname` of the workstation connecting to a Tor exit relay?

WKST-HR-02

splunk>enterprise Apps ▾ Messages ▾ Settings ▾ Activity ▾ Help ▾ Find

Search Analytics Datasets Reports Alerts Dashboards Search & Report

New Search Save As ▾ Create Table View Close

```

1 index=lab sourcetype=fortigate_traffic
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_org dst_category dst_risk
3 | where dst_risk="high" OR dst_risk="critical"
4 | table _time srcip srcname dstip dstport proto sentbyte rcvbyte dst_asn_org dst_category dst_risk
5 | sort _time

```

✓ 10 events (before 9/2/26 5:24:35.000 AM) No Event Sampling ▾ Job ▾ || ■ ↶ ↷ ⬇ ⬆ Smart Mode ▾

Events Patterns **Statistics (10)** Visualization

20 Per Page ▾ Format Preview ▾

_time ▾	srcip ▾	srcname ▾	dstip ▾	dstport ▾	proto ▾	sentbyte ▾	rcvbyte ▾	dst_asn_org ▾	dst_category ▾	dst_risk ▾
2026-03-22 10:00:00	10.10.11.18	WKST-HR-02	185.220.101.34	443	6	2841	2650	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:02:00	10.10.11.18	WKST-HR-02	185.220.101.34	443	6	2956	2890	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:04:00	10.10.11.18	WKST-HR-02	185.220.101.34	443	6	3102	2700	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:06:00	10.10.11.18	WKST-HR-02	185.220.101.34	443	6	2778	2600	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:08:00	10.10.11.18	WKST-HR-02	185.220.101.34	443	6	3045	2980	F3 Netze e.V.	Tor Exit / Anonymisation	high
2026-03-22 10:10:00	10.10.11.18	WKST-HR-02	185.220.101.34	443	6	2901	2750	F3 Netze e.V.	Tor Exit / Anonymisation	high

Task 7 - Putting It Together: Closing the Case

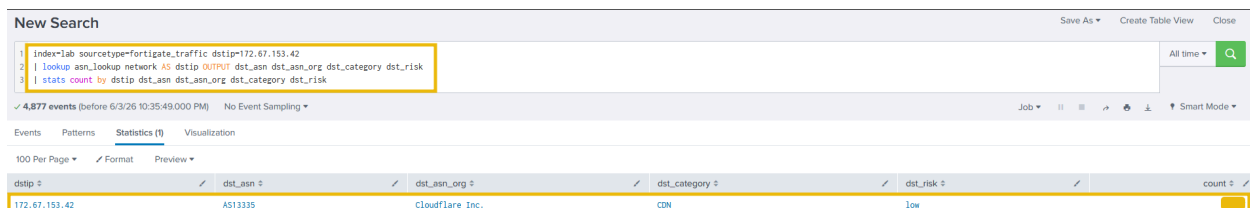
In Task 1, we left an alert open: sustained connections to a clean Cloudflare IP, 847 MB outbound, no DNS record, no readable SNI. Each task since then has added another piece to the investigative toolkit. Now we close the case. Same host, sixteen days later. Work through the steps below in order.

The Alert: No DNS record, no readable SNI, IP reputation clean. Let's begin.

```
Alert: Large Outbound Transfer
Source:      10.10.15.44 (WKST-FINANCE-04)
Destination: 172.67.153.42:443
Protocol:    UDP
Bytes Out:   847 MB
Duration:    4h 12m
Time:        2026-04-02 02:47 UTC
```

Step 1: IP Reputation and ASN Check: Let's establish what we actually know about the destination IP:

```
index=lab sourcetype=fortigate_traffic dstip=172.67.153.42
| lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_o
rg dst_category dst_risk
| stats count by dstip dst_asn dst_asn_org dst_category dst_r
isk
```



New Search

1 index=lab sourcetype=fortigate_traffic dstip=172.67.153.42
2 | lookup asn_lookup network AS dstip OUTPUT dst_asn dst_asn_org dst_category dst_risk
3 | stats count by dstip dst_asn dst_asn_org dst_category dst_risk

✓ 4,877 events (before 6/3/26 10:35:49.000 PM) No Event Sampling

Events Patterns Statistics (1) Visualization

100 Per Page Format Preview

dstip	dst_asn	dst_asn_org	dst_category	dst_risk	count
172.67.153.42	AS13335	Cloudflare Inc.	CDN	low	1

As we can see, this is Cloudflare infrastructure. Reputation returns clean because that is the correct result for a CDN serving millions of domains simultaneously. IP triage is closed, and we pivot to behavioral analysis.

Step 2: Full Connection History: Let's examine whether the April 2 transfer is an isolated event or part of a longer pattern:

```
index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dsti
p=172.67.153.42
```

New Search

Save As Create Table View Close

```
Index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42
| timechart span=id sum(sentbyte) as daily_bytes_out count as daily_connections
```

All time

4,486 events (before 6/4/26 12:19:00 PM)

No Event Sampling

Job

Smart Mode

Events Patterns Statistics (31) Visualization

100 Per Page Format Preview

_time	daily_bytes_out	daily_connections
2026-04-02	848115557	212
2026-04-01	1630998	216
2026-03-31	1546262	215
2026-03-17	1467368	214
2026-03-07	1246668	6
2026-04-04	1232379	214
2026-03-27	1212525	214
2026-03-24	1096744	215
2026-03-28	891877	215

Step 3: Confirm the Exfiltration Event: Step 2 returned a daily total across all connections on April 2. To isolate the individual exfiltration event, let's filter to that day and sort by bytes sent to surface the largest connection first:

New Search Save As Create Table View Close

```

1 index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42 earliest="04/02/2026:00:00:00" latest="04/03/2026:00:00:00"
2 | table _time srcip dstip dstport proto sentbyte rcvdbyte duration
3 | sort -sentbyte

```

✓ 212 events (before 4/3/26 12:00:00.000 AM) No Event Sampling Job Smart Mode

Events Patterns **Statistics (212)** Visualization

100 Per Page Format Preview Prev 1 2 3 Next

_time	srcip	dstip	dstport	proto	sentbyte	rcvdbyte	duration
2026-04-02 02:47:00	10.10.15.44	172.67.153.42	443	17	847152	2097152	15180
2026-04-02 16:02:41	10.10.15.44	172.67.153.42	443	17	81492	276724	113
2026-04-02 09:19:46	10.10.15.44	172.67.153.42	443	17	1198	355	3
2026-04-02 18:47:57	10.10.15.44	172.67.153.42	443	17	1197	217	3
2026-04-02 13:08:17	10.10.15.44	172.67.153.42	443	17	1197	368	2
2026-04-02 20:24:19	10.10.15.44	172.67.153.42	443	17	1196	205	5
2026-04-02 15:04:09	10.10.15.44	172.67.153.42	443	17	1193	316	1
2026-04-02 21:19:54	10.10.15.44	172.67.153.42	443	17	1189	382	1
2026-04-02 11:47:32	10.10.15.44	172.67.153.42	443	17	1186	200	2
2026-04-02 15:27:40	10.10.15.44	172.67.153.42	443	17	1183	374	2
2026-04-02 16:32:11	10.10.15.44	172.67.153.42	443	17	1182	293	5
2026-04-02 21:36:02	10.10.15.44	172.67.153.42	443	17	1180	341	3

Looking at the output, all 212 connections on April 2 are returned. The top record is immediately identifiable: 2026-04-02 02:47 UTC, protocol 17 (UDP/QUIC), sentbyte 847 MB out, rcvdbyte 2,097,152 (2 MB in), duration 15,180 seconds (4 hours 12 minutes). The remaining 211 records show sentbyte values in the 1,100–1,200 byte range; these are the regular C2 beacon keepalives that continued to fire throughout the day. The contrast confirms the exfiltration event. The byte asymmetry is consistent with exfiltration. The next step is process attribution via Sysmon.

Step 4: Process Attribution via Sysmon: Two network-layer sources confirmed that the connection exists. Neither can tell us what is generating it. Let's query Sysmon:

```

index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
| stats count by Image ProcessId
| sort -count

```

New Search Save As Create Table View Close

```

1 index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
2 | stats count by Image ProcessId
3 | sort -count

```

6,140 events (before 6/3/26 10:38:51.000 PM) No Event Sampling

Events Patterns **Statistics (17)** Visualization

100 Per Page Format Preview

Image	ProcessId	count
C:\Program Files\Microsoft Office\Office16\EXCEL.EXE	4812	6000+
C:\Program Files\Google\Chrome\Application\chrome.exe	1456	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2083	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2686	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2915	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2986	2
C:\Program Files\Google\Chrome\Application\chrome.exe	5898	2
C:\Program Files\Google\Chrome\Application\chrome.exe	7316	2
C:\Program Files\Mozilla Firefox\firefox.exe	1057	2
C:\Program Files\Mozilla Firefox\firefox.exe	3897	2
C:\Program Files\Mozilla Firefox\firefox.exe	3905	2

Looking at the output, **EXCEL.EXE** (PID 4812) accounts for 6,000+ connections, far more than any other process. Chrome and Firefox appear across multiple process IDs, each with just 2 connections, consistent with incidental browsing activity hitting the same Cloudflare IP. The gap between 6,000+ and 2 is the signal. Now let's confirm this process was active continuously across multiple days:

```

index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
| bin _time span=1d
| stats count by _time Image ProcessId
| where match(Image, "EXCEL.EXE")
| sort _time
| head 5

```

New Search Save As Create Table View Close

```

1 index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
2 | bin _time span=1d
3 | stats count by _time Image ProcessId
4 | where match(Image, "EXCEL.EXE")
5 | sort _time
6 | head 5

```

6,140 events (before 6/3/26 10:47:27.000 PM) No Event Sampling

Events Patterns **Statistics (5)** Visualization

100 Per Page Format Preview

_time	Image	ProcessId	count
2026-03-17	C:\Program Files\Microsoft Office\Office16\EXCEL.EXE	4812	278
2026-03-18	C:\Program Files\Microsoft Office\Office16\EXCEL.EXE	4812	282
2026-03-19	C:\Program Files\Microsoft Office\Office16\EXCEL.EXE	4812	306
2026-03-20	C:\Program Files\Microsoft Office\Office16\EXCEL.EXE	4812	274
2026-03-21	C:\Program Files\Microsoft Office\Office16\EXCEL.EXE	4812	298

As we can see, PID 4812 consistently made connections from March 17 onward, with daily counts in the 270-310 range. Microsoft Excel is not a QUIC client. A

legitimate session does not beacon at machine-clock regularity for 16 days. This is the pivotal finding: only Sysmon told us what was responsible.

Step 5: Confirm QUIC Transport in Zeek: Let's validate the transport protocol from a second independent source:

```
index=lab sourcetype=zeek_conn "id.orig_h"="10.10.15.44" "id.  
resp_h"="172.67.153.42"  
| stats count by proto service duration  
| sort -count
```

proto	service	duration	count
udp	quic	1.0	903
udp	quic	5.0	892
udp	quic	4.0	886
udp	quic	2.0	872
udp	quic	3.0	862
udp	quic	99.0	4
udp	quic	113.0	3
udp	quic	137.0	3

Looking at the output, Zeek independently confirms QUIC across every session. The single largest extended session in the results is the April 2 exfiltration. QUIC bypassed proxy inspection entirely, which is why no proxy log exists for any of these sessions.

Step 6: Check for DNS Queries From WKST-FINANCE-04: Why was there no DNS record in the original alert? Let's answer it in two steps. First, let's confirm whether this host uses DNS at all:

```
index=lab sourcetype=zeek_conn "id.orig_h"="10.10.15.44" "id.  
resp_p"=53 proto=udp  
| timechart span=1d count
```

New Search Save As Create Table View Close

`index=lab sourcetype=zeek_conn "id.orig_h"="10.10.15.44" "id.resp_p"=53 proto=udp` All time Q

✓ 2,575 events (before 4/16/26 2:26:55.000 PM) No Event Sampling

Events (2,575) Patterns Statistics (31) Visualization

100 Per Page Format Preview

_time	count
2026-03-07	75
2026-03-08	106
2026-03-09	119
2026-03-10	62
2026-03-11	91
2026-03-12	70
2026-03-13	103
2026-03-14	76
2026-03-15	116
2026-03-16	67
2026-03-17	82
2026-03-18	82
2026-03-19	60
2026-03-20	78
2026-03-21	60
2026-03-22	61

The output shows consistent UDP/53 traffic across the dataset, with 60-120 queries per day. WKST-FINANCE-04 uses DNS normally for its browsing activity. Now let's ask the more specific question: was `172.67.153.42` ever resolved via DNS?

```
index=lab sourcetype=zeek_dns "id.orig_h"="10.10.15.44"
| search answers="172.67.153.42" OR query="172.67.153.42"
```

New Search Save As Create Table View Close

`index=lab sourcetype=zeek_dns "id.orig_h"="10.10.15.44"`
`| search answers="172.67.153.42" OR query="172.67.153.42"` All time Q

✓ 0 events (before 6/3/26 11:08:23.000 PM) No Event Sampling

Events (0) Patterns Statistics Visualization

No results found.

Zero results. This host generates hundreds of DNS queries per day, yet never looks up `172.67.153.42`. The reason is straightforward: `EXCEL.EXE` is connected to the destination via a hardcoded IP address, with no hostname to resolve. DNS was bypassed entirely, which is why the original alert had no DNS record to investigate.

Step 7: How Long Has EXCEL.EXE (PID 4812) Been Running? Let's calculate the precise compromise window:

```
index=lab sourcetype=sysmon Image="*EXCEL.EXE" ProcessId=4812
SourceIp=10.10.15.44
| stats min(_time) as first_seen max(_time) as last_seen count
| eval first_seen=strftime(first_seen,"%Y-%m-%d %H:%M:%S")
| eval last_seen=strftime(last_seen,"%Y-%m-%d %H:%M:%S")
```

New Search

index=lab sourcetype=sysmon Image="*EXCEL.EXE" ProcessId=4812 SourceIp=10.10.15.44
| stats min(_time) as first_seen max(_time) as last_seen count
| eval first_seen=strftime(first_seen,"%Y-%m-%d %H:%M:%S")
| eval last_seen=strftime(last_seen,"%Y-%m-%d %H:%M:%S")

3,060 events (before 4/16/26 2:27:35.000 PM) No Event Sampling

Events (3,060) Patterns Statistics (1) Visualization

100 Per Page Format Preview

first_seen	last_seen	count
2026-03-17 07:59:31		

Looking at the output, PID 4812 has been running continuously for 16 days without a single restart. A macro-enabled workbook opened on the `first_seen` date established C2 beaconing immediately and waited before executing the final exfiltration. The alert we responded to was not the start of this incident; it was the end.

Answer the questions below

How many bytes were transferred outbound in the April 2 exfiltration event?

847823104

splunk>enterprise Apps Messages Settings Activity Help Find

Search Analytics Datasets Reports Alerts Dashboards Search & Reporting

New Search

Save As Create Table View Close

```
1 index=lab sourcetype=fortigate_traffic srcip=10.10.15.44 dstip=172.67.153.42 earliest="04/02/2026:00:00:00" latest="04/03/2026:00:00:00"
2 | table _time srcip dstip dstport proto sentbyte rcvbyte duration
3 | sort -sentbyte
```

✓ 212 events (before 4/3/26 12:00:00.000 AM) No Event Sampling Job II ↗ ↕ ⬇ Smart Mode

Events Patterns **Statistics (212)** Visualization

20 Per Page Format Preview

_time	srcip	dstip	dstport	proto	sentbyte	rcvbyte	duration
2026-04-02 02:47:00	10.10.15.44	172.67.153.42	443	17	347823144	2097152	15180
2026-04-02 16:02:41	10.10.15.44	172.67.153.42	443	17	81492	276724	113
2026-04-02 09:19:46	10.10.15.44	172.67.153.42	443	17	1198	355	3
2026-04-02 18:47:57	10.10.15.44	172.67.153.42	443	17	1197	217	3
2026-04-02 13:08:17	10.10.15.44	172.67.153.42	443	17	1197	368	2
2026-04-02 20:24:19	10.10.15.44	172.67.153.42	443	17	1196	205	5
2026-04-02 15:04:09	10.10.15.44	172.67.153.42	443	17	1193	316	1

Run the process count query. How many connections does **EXCEL.EXE** make to **172.67.153.42** ?

6108

splunk>enterprise Apps Messages Settings Activity Help Find

Search Analytics Datasets Reports Alerts Dashboards Search & Reporting

New Search

Save As Create Table View Close

```
1 index=lab sourcetype=sysmon SourceIp=10.10.15.44 DestinationIp=172.67.153.42
2 | stats count by Image ProcessId
3 | sort -count
```

✓ 6,140 events (before 9/2/26 5:31:59.000 AM) No Event Sampling Job II ↗ ↕ ⬇ Smart Mode

Events Patterns **Statistics (17)** Visualization

20 Per Page Format Preview

Image	ProcessId	count
C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	4812	6108
C:\Program Files\Google\Chrome\Application\chrome.exe	1456	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2083	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2686	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2915	2
C:\Program Files\Google\Chrome\Application\chrome.exe	2986	2

What is the **last_seen** timestamp for **EXCEL.EXE** (PID 4812)?

2026-04-06 21:55:44

The screenshot shows the Splunk Enterprise Search interface. The search bar contains the following query:

```

1 index=lab sourcetype=sysmon Image="EXCEL.EXE" ProcessId=4812 SourceIp=10.10.15.44
2 | stats min(_time) as first_seen max(_time) as last_seen count
3 | eval first_seen=strftime(first_seen,"%Y-%m-%d %H:%M:%S")
4 | eval last_seen=strftime(last_seen,"%Y-%m-%d %H:%M:%S")

```

The search results show 6,108 events. The table below displays the first event:

first_seen	last_seen	count
2026-03-17 07:59:38	2026-04-06 21:55:44	6108

Task 8 - Conclusion

Step	Data Source	Finding
1. IP / ASN	FortiGate + ASN Lookup	AS13335 (Cloudflare). Clean reputation. CDN.
2. Connection History	FortiGate time chart	Beaconing from March 17, every 4 min, for 16 days
3. Exfil Event	FortiGate	April 2 02:47 UTC, 847 MB, UDP/QUIC
4. Process Attribution	Sysmon EventID 3	EXCEL.EXE PID 4812, 3,060 connections over 16 days
5. Transport	Zeek	QUIC confirmed. Proxy bypass confirmed.
6. DNS Check	Zeek DNS	No UDP/53 from host. DoH in use.
7. Persistence	Sysmon	PID 4812 active March 17 to April 2, 16 days without restart

Assessment: Confirmed data exfiltration via QUIC through Cloudflare CDN infrastructure. **EXCEL.EXE** (PID 4812) beaconed every 4 minutes from March 17 and exfiltrated 847 MB on April 2 at 02:47 UTC, running for 16 days without restarting. There was no DNS record, no proxy log, and no SNI. The investigation succeeded only because Sysmon was deployed on WKST-FINANCE-04.

Extracted IOCs

Indicator Type	Value	Context
Internal Host	10.10.15.44 (WKST-FINANCE-04)	Compromised host
C2 IP	172.67.153.42	Cloudflare-proxied C2

Indicator Type	Value	Context
C2 ASN	AS13335	Cloudflare, Inc.
Malicious Process	EXCEL.EXE (PID 4812)	C2 beaconing and exfiltration via QUIC
Process Path	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	Responsible for 3,060 connections over 16 days
Beacon Interval	240 seconds (4 minutes)	Active from March 17, 2026
Exfil Event	2026-04-02 02:47 UTC	847 MB outbound
Transport	UDP/443 (QUIC)	Bypassed proxy; missed by TCP IDS rules

Room Summary: Modern networks have outpaced the monitoring assumptions on which most detection stacks were built. This room walked through why that happened and what an analyst can do about it.

